PROPOSAL

AI SRE Copilot Dev Pilot

Technical Architecture, Security Guardrails and Approval Enforcement

Proposal item	Details
Environment	Quantum Integrators (QI) internal Google Cloud project
Duration	4–6 weeks from approval and access readiness
Proposed budget	USD 250, subject to confirmation of coverage period and cost validation
Pilot coordinator	Gupteswar Mishra
Technical implementation lead	Akshay Saxena
Business sponsors / approvers	Ken / Prithiviraj
Decision requested	Conditional approval to complete readiness gates and then execute the QI-only pilot

CONFIDENTIALITY AND SCOPE

This proposal covers a controlled development pilot in QI's internal GCP environment only. It does not authorize access to, deployment in, or use of credentials or data from GSK. Any future GSK implementation requires separate architecture, security, access, budget and go-live approvals.

1. Executive Summary

This proposal seeks approval to validate the feasibility of an AI-assisted Site Reliability Engineering (SRE) Copilot in the QI internal GCP project. The pilot will connect monitoring signals and relevant logs to an AI-assisted diagnosis service, produce evidence-linked recommendations, and route eligible actions through predefined GitHub Actions workflows with mandatory human approval.

The Copilot will recommend actions, not execute model-generated commands. A deterministic policy layer will validate the proposed action and parameters against an allowlist. Privileged execution will be isolated from the AI diagnosis identity and will occur only through an approved workflow after authorization.

Recommendation	Conditions
Conditionally approve the QI development pilot	Written scope and budget approval; named owners; access readiness; validated approval controls; security review.
Keep remediation disabled until controls pass	No privileged execution until negative IAM tests and approval-bypass tests demonstrate enforcement.
Do not treat the pilot as production certification	Results inform a proceed, extend-with-conditions, or stop recommendation only.

2. Business Objectives and Expected Outcomes

- Detect representative service incidents using Grafana dashboards, alerts and approved GCP telemetry.
- Correlate related alerts and collect bounded diagnostic evidence, including selected logs and deployment metadata.
- Use Vertex AI Gemini and approved runbooks to generate structured, evidence-linked diagnosis and remediation recommendations.
- Route supported recommendations through existing GitHub Actions workflows, with human approval before privileged changes.
- Record the incident, evidence, recommendation, approval decision, execution result and post-action health outcome.
- Evaluate diagnostic usefulness, workflow safety, auditability, cost and operational time improvement.

3. Scope and Boundaries

In scope

- A gradual pilot covering up to 10–20 lightweight Cloud Run services across us-east1 and us-central1, subject to measured usage and budget.
- Grafana Community Edition dashboards, alerts and representative service-level objectives.
- Authenticated incident intake, correlation, bounded AI diagnosis and structured recommendations.
- Predefined CI/CD actions, mandatory approval, health checks and audit records.
- Five controlled scenarios: bad deployment, startup failure/crash loop, quota exhaustion, disabled API and configuration drift.
- At least 10 scored test runs, plus negative tests for approval rejection, duplicate delivery, invalid model output and service/workflow failure.

Out of scope

- Any GSK environment access, deployment, credential use or data processing.
- Autonomous infrastructure changes or direct execution of arbitrary AI-generated commands.
- Automated IAM changes, database operations, regional failover and quota increases.
- Production rollout, production-readiness certification or any implied authorization for a GSK implementation.
- New paid GitHub or software subscriptions unless separately approved.

4. Proposed Architecture

Layer	Responsibilities	Security boundary
Telemetry	Cloud Monitoring, Cloud Logging, relevant Audit Logs and Grafana	Read only; approved data sources; restricted access.
Incident intake	Authenticate alert sources, validate payloads, deduplicate and correlate incidents	No privileged execution permissions.
AI diagnosis	Use selected evidence, deployment metadata, approved runbooks and Vertex AI Gemini	Read-only identity; no infrastructure write access.
Policy validation	Validate schema, action allowlist, target, parameters, scope and idempotency	Reject unknown actions; model output is untrusted input.
Approval	Present exact incident and proposed action to authorized reviewers	Approval bound to exact proposal; changes require reapproval.
Execution	Invoke a predefined protected GitHub Actions workflow	Separate short-lived execution identity; narrow resource permissions.
Validation and audit	Run health checks and record approval, workflow, actor, outcome and evidence	Traceable audit record and controlled retention.

Design principle: AI proposes; deterministic policy validates; an authorized human approves; a protected workflow executes; automated checks and audit records verify the outcome.

5. IAM and Security Design

5.1 Identity separation

Identity	Minimum required access	Prohibited capability
Telemetry collector	Read approved metrics, logs and service metadata	No deployment or IAM write access
AI diagnosis service	Invoke approved Vertex AI model and read selected evidence/runbooks	No infrastructure modification or workflow execution
Incident intake	Authenticate, validate and record incident events	No privileged GCP access
Workflow dispatcher	Invoke only the approved workflow mechanism	No broad infrastructure administrator role
Remediation executor	Perform approved action on designated QI resources	No broad Owner/Editor role; no GSK access
Human approver	Approve/reject through protected workflow	No implicit authority from model output

5.2 Mandatory security controls

- Use GitHub-to-GCP Workload Identity Federation with short-lived credentials where supported; avoid long-lived service-account keys.
- Restrict federation trust to the intended GitHub organization, repository, protected branch/environment and workflow identity.
- Grant narrow roles and service-account impersonation permissions only where required; avoid broad project-level grants.
- Keep privileged credentials out of the AI analysis job and make them available only to the protected execution job after approval.
- Redact secrets and sensitive payloads before model invocation; use synthetic or explicitly approved QI data only.
- Treat logs, incident descriptions and retrieved runbooks as untrusted input; do not permit prompt content to alter policy or call tools directly.
- Protect Grafana and incident intake with authentication, authorization, restricted network access and rate limits.
- Enable relevant audit logging and apply retention limits; assess Data Access log costs before enabling broadly.
- Use request limits, timeouts, token budgets, schema validation and safe failure handling for unavailable or malformed AI responses.
- Configure cost alerts at 50%, 75%, 90% and 100%; treat alerts as notifications, not a hard spending cap.

6. Human Approval and Privileged Execution

1. Create a proposal record with incident ID, target, action type, exact revision/configuration, evidence, risk, validation and rollback plan.
2. Validate the proposal against a deterministic allowlist. Reject unsupported actions and invalid or out-of-scope parameters.
3. Use a protected GitHub Actions environment with required reviewers and branch restrictions, after confirming the QI repository plan supports the required protections.
4. Bind the approval to the exact proposal and verify that its target and parameters remain unchanged. Material changes require reapproval.
5. Ensure privileged credentials are available only to the protected execution job. Block alternate dispatch paths and untrusted branches.
6. Apply idempotency keys and concurrency controls to prevent duplicate remediation.
7. Run post-action health checks and record the result. Failed or inconclusive recovery must be escalated; rollback must follow a separately authorized path.

Approval bypass tests

Test	Expected result
No approval or rejected approval	No infrastructure change
Expired/cancelled approval	No infrastructure change
Proposal changed after approval	Approval invalidated; new approval required
Duplicate incident or repeated dispatch	No duplicate remediation
Unauthorized branch/actor	Cannot obtain privileged credentials
Workflow rerun with stale approval	Fresh validity checks required
Approval controls unavailable	Privileged remediation remains disabled

Go/no-go rule: Privileged remediation remains disabled until all applicable approval and bypass tests pass.

7. Delivery Plan and Milestones

Phase	Timing	Key activities and exit gate
0. Approval and readiness	Before Week 1	Confirm scope, budget period, owners, access, GitHub plan, approvers and data handling. No provisioning before exit gate.
1. Foundation and security	Week 1	Configure billing, APIs, IAM, federation, audit, budget alerts and two representative Cloud Run services. Prove AI identity is non-privileged.
2. Monitoring and intake	Week 2	Deploy restricted Grafana, dashboards, SLOs, authenticated alert delivery, deduplication and incident evidence schema.
3. AI diagnosis	Week 3	Integrate Vertex AI, bounded evidence, approved runbooks, schema validation, redaction, action allowlist and safe failure handling.
4. CI/CD and approval	Week 4	Integrate protected workflows, approval binding, expiry/rejection paths, idempotency, post-action checks and audit trail.
5. Scenario evaluation	Week 5	Run five scenarios and at least 10 scored runs; test negative paths, approval bypass and failures.
6. Review and cleanup	Week 6 or earlier	Review results, spend, limitations and risks; demonstrate flow; remove test resources and revoke temporary access unless retention is approved.

8. Budget Proposal

Proposed budget ceiling: USD 250. The allocation below is a planning estimate, not a validated quotation. Approval is conditional on confirming whether the amount covers the full 4–6 week pilot or a monthly period.

Cost category	Proposed allocation	Validation needed
Cloud Run services and copilot runtime	USD 45	Service count, requests, CPU/memory, scale-to-zero assumptions
Grafana hosting and storage	USD 40	Host size, uptime, storage and retention
Vertex AI Gemini usage	USD 55	Model, region, token volume, quotas and retries
Logging, monitoring and audit storage	USD 30	Log volume, enabled audit categories and retention
Artifact storage, secrets and networking	USD 20	Storage, networking and secret-management usage
Contingency	USD 60	Reserved for variance; use requires pilot coordinator review
TOTAL	USD 250	Subject to confirmation and pricing validation

- Engineering effort is excluded.
- No new paid GitHub or other software subscription is included.
- Taxes, currency conversion and material data-transfer charges must be checked.
- Grafana Community Edition has no license fee, but hosting and operation still cost money.
- Start with two services and expand only after measuring actual usage.
- Review spend daily during fault testing. Pause nonessential testing at 90% pending forecast review.
- Budget notifications do not enforce a hard cap. Define and test an operational stop procedure.

9. Success Criteria and Acceptance

Measure	Proposed acceptance criterion
Diagnostic accuracy	At least 90% correct primary diagnoses across at least 10 scored runs
Scenario coverage	All five scenarios exercised; live and simulated evidence clearly labelled
Pipeline enforcement	Zero infrastructure changes outside approved CI/CD workflows
Human approval	100% of executed remediations have recorded approval before execution
Restricted actions	Zero automated IAM, database or regional failover actions
Auditability	Every test links evidence, recommendation, decision, execution and outcome
Duplicate protection	Repeated delivery of the same incident does not cause duplicate remediation
Time improvement	Measure median alert-to-approved-fix time against a manual baseline; agree target at kickoff
Budget	Spend remains within confirmed approved envelope
Isolation	No GSK resources, credentials or data used

Measurement caveat: ten runs provide an initial pilot signal, not statistical evidence of production reliability. The 90% threshold must be assessed alongside scenario coverage and failure evidence.

10. Key Risks and Mitigations

Risk	Mitigation
Incorrect AI recommendation	Require supporting evidence, approved runbooks, deterministic validation and human review.
Approval bypass	Separate identities, protected execution environment, proposal binding and explicit negative tests.
Sensitive data exposure	Synthetic/approved QI data, redaction, least privilege and security review.
Prompt injection in logs	Treat telemetry as untrusted; prevent model output from directly invoking tools.

Cost overrun	Gradual scale-up, daily review, usage limits, budget alerts and shutdown procedure.
Missing permissions or quotas	Complete preflight checks before starting the delivery timeline.
Duplicate remediation	Idempotency keys, concurrency controls and repeated-delivery testing.
Fault testing impacts shared resources	Isolated services, bounded fault injection, documented recovery and test windows.

11. Governance and Ownership

Role	Proposed owner	Accountability
Business sponsors	Ken / Prithiviraj	Budget and pilot authorization
Pilot coordinator	Gupteswar Mishra	Scope, dependencies, stakeholder reviews and final recommendation
Technical implementation lead	Akshay Saxena	Blueprint, development, integration and testing
Cloud/platform team	Assigned engineer	GCP project, billing, IAM, quotas and infrastructure
CI/CD owner	Assigned engineer	Workflow integration, approval gates and deployment permissions
Security reviewer	Assigned reviewer	Data handling, access controls, guardrails and bypass review
Remediation approvers	Named authorized engineers	Approve or reject each proposed privileged action

Named owners and approvers must be confirmed at kickoff. Roles may be combined only where separation-of-duties requirements remain satisfied.

12. Decisions Requested

8. Approve the QI-only development pilot scope and explicitly exclude GSK implementation.
9. Confirm whether USD 250 covers the entire pilot or a monthly period.
10. Confirm named owners, authorized approvers and escalation contacts.
11. Confirm the GitHub plan and repository settings can enforce the required approval controls.
12. Approve the use of synthetic or explicitly approved QI data with Vertex AI and agreed redaction controls.
13. Authorize resource provisioning only after the readiness gate is completed.
14. Require a final review before any extension, production rollout or proposed GSK implementation.

13. Final Recommendation

Approve the AI SRE Copilot Dev Pilot in principle, subject to readiness conditions. Begin with two lightweight services and a recommendation-first workflow. Enable privileged remediation only after IAM isolation, approval enforcement, auditability and negative security tests have passed. Keep spend within the confirmed budget envelope and document all limitations.

A successful QI pilot does not authorize implementation in GSK. A separate GSK proposal, environment-specific architecture and security assessment, access approvals, budget authorization and formal go-live decision are required.

Appendix A. Reference Documentation

- **Google Cloud Workload Identity Federation security best practices:** https://docs.cloud.google.com/iam/docs/best-practices-for-using-workload-identity-federation
- **Google Cloud service-account security best practices:** https://docs.cloud.google.com/iam/docs/best-practices-service-accounts

- **GitHub Actions deployment protection and approvals:** https://docs.github.com/en/actions/how-tos/deploy/configure-and-manage-deployments/control-deployments
- **Google Cloud Billing budgets and alerts:** https://docs.cloud.google.com/billing/docs/how-to/budgets
- **SAP/Grafana/Vertex AI implementation details:** To be finalized during technical design and preflight validation.